



Assignment 5.1: Security Hardening Plan and Project Change Request (PCR)

Christian Calipusan, Shivam Patel, Joshua Remington and Mikailou Nikiema

Shiley-Marcos School of Engineering (SMSE), University of San Diego

CYBR-514-01B: Cyber Engineering Research I

Professor Douglas Magedman

06/08/2026

		Security Hardening Plan and Project Change Request (PCR)	Client	Design World
			Doc #	DW0006
Effective Date	06/08/26		Rev. #	Rev 1

Executive Summary

Four Point Cyber Consulting submits this security hardening plan following the completed vulnerability assessment and penetration test done on Design World's sandbox network. The vulnerability assessment and penetration test identified key weaknesses that could lead to unauthorized access, privilege escalation, lateral movement, data exposure, and service availability. This plan and the change requests outline the prioritized remediation of high-risk vulnerabilities and aim to strengthen the environment's overall security posture.

These changes focus on the Design World's production architecture, including the Public Subnet, Business Subnet, Website Subnet, and Transit Services VLAN. The recommended security controls and configuration changes provide stronger protection of these areas without disrupting the daily business operations.

This security hardening plan, along with the change requests, provides a clear roadmap for implementing effective remediations in a controlled manner. Implementation of these hardening measures will be executed following the approval from Design World. Four Point Cyber Consulting will confirm successful implementation and conduct a post-hardening vulnerability assessment and penetration test in the weeks following implementation.

		Security Hardening Plan and Project Change Request (PCR)	Client	Design World
			Doc #	DW0006
Effective Date	06/08/26		Rev. #	Rev 1

Table of Contents

1. Scope.....	2
2. Objectives.....	3
3. Background.....	4
4. Scope of Hardening Measures.....	5
5. Hardening Measures.....	5
5.1 Configuration Changes.....	5
5.2 Policy Changes.....	6
5.3 Security Control Updates.....	7
6. Project Change Request Overview.....	7
7. Implementation Plan.....	8
7.1 Timeline.....	8
7.2 Resources.....	8
7.3 Training.....	9
8. Conclusion and Next Steps.....	9
9. Attachments.....	9
10. Approvals.....	10

		Security Hardening Plan and Project Change Request (PCR)	Client	Design World
			Doc #	DW0006
Effective Date	06/08/26		Rev. #	Rev 1

1. Scope

This security hardening plan outlines the targeted implementation of security hardening controls following the vulnerability assessment and penetration test done on Design World's network.

This plan will focus on the following systems in the environment:

a. OpenVPN Server

- Public Subnet IP: 172.16.200.2
- Transit VLAN IP: 192.168.100.1

b. Windows Server 2022 Domain Controller

- Hostname: DW-DC-OL-1
- Business Subnet IP: 172.16.1.10
- Transit VLAN IP: 192.168.100.10

c. Windows Server 2022 File Server

- Hostname: DW-FS-OL-1
- Business Subnet IP: 172.16.1.20
- Transit VLAN IP: 192.168.100.20

d. Ubuntu 22.04 LTS Workstation

- Hostname: DW-U22-OL-1
- Business Subnet IP: 172.16.1.40
- Transit VLAN IP: 192.168.100.40

e. CentOS Stream 9 Web Server

- Hostname: DW-CS9W-OL-1
- Business Subnet IP: 172.16.10.50
- Transit VLAN IP: 192.168.100.50

Hardening activities will be performed exclusively in the sandbox environment and will prioritize high-risk vulnerabilities that could disrupt Design World's confidentiality, integrity, or availability. The scope includes system configuration changes, service hardening, system and service updates, and vital changes. Validation testing will confirm that the changes made were successfully applied and functionality is not disrupted.

		Client	Design World
		Doc #	DW0006
Effective Date	06/08/26	Rev. #	Rev 1

2. Objectives

The objective of this Security Hardening Plan and Project Change Request is to define the security improvements needed to reduce the risks identified during the Vulnerability Assessment and Penetration Test of the Design World sandbox environment. This plan provides a structured approach for implementing approved configuration changes, policy updates, system updates, and security control improvements across the affected systems.

The hardening effort is intended to address confirmed vulnerabilities that could support unauthorized access, credential exposure, insecure communication, or unauthorized data access. The plan will focus on reducing risk while maintaining system availability and minimizing disruption to Design World's normal operations.

Specific objectives of this hardening plan include:

- Remediate confirmed vulnerabilities identified during the vulnerability assessment and penetration test.
- Apply missing security updates to affected Windows Server systems, including the Domain Controller and File Server.
- Strengthen Windows authentication controls by disabling legacy LM and NTLMv1 authentication and enforcing stronger authentication methods.
- Enforce SMB signing to reduce the risk of SMB relay and man-in-the-middle attack paths.
- Correct insecure Windows service permissions that could support local privilege escalation.
- Restrict world-readable NFS shares to authorized hosts and users only.
- Update vulnerable OpenSSL packages and remove package hold settings that prevent security updates from being applied.
- Remove or disable unencrypted Telnet services and require secure remote administration methods.
- Improve system hardening by updating configurations to align with security best practices and applicable STIG guidance.
- Provide Project Change Requests for CCB review and approval before implementing hardening activities.
- Validate that all approved changes have been successfully implemented and do not adversely affect system functionality.

 FOUR POINT — CYBER CONSULTING —		Security Hardening Plan and Project Change Request (PCR)	Client	Design World
			Doc #	DW0006
Effective Date	06/08/26		Rev. #	Rev 1

3. Background

Four Point Cyber Consulting completed a Vulnerability Assessment and Penetration Test of the Design World sandbox mirror environment to evaluate the security posture of systems supporting Design World’s cloud-based infrastructure and remote access. The assessment covered systems within the Public Subnet, Business Subnet, Website Subnet, and Transit and Services VLAN.

The Vulnerability Assessment identified several areas requiring security improvement, including missing security updates, weak authentication settings, SMB weaknesses, exposed Telnet services, world-readable NFS shares, outdated OpenSSL packages, and other insecure configuration items. These findings showed that while the environment has security controls in place, several systems still contain weaknesses that could increase risk if exploited by an attacker with internal network access. A Penetration Test was then conducted to validate selected vulnerabilities from the assessment in a controlled and approved manner. Testing confirmed several findings across the Domain Controller, File Server, Ubuntu Workstation, and Transit and Services VLAN.

The results of the penetration test showed that the most significant risks are related to weak authentication controls, insecure file sharing, legacy protocols, unencrypted management access, and insufficient patching. These weaknesses could enable credential attacks and unauthorized access to sensitive data if left unresolved.

This Security Hardening Plan builds on the results of both the Vulnerability Assessment and Penetration Test by translating confirmed security findings into actionable remediation activities. The accompanying Project Change Requests provide the formal change approval path for implementing these hardening measures through the Configuration Control Board. Once approved, the changes will be implemented in a controlled manner, followed by validation to confirm that vulnerabilities have been remediated and that Design World’s systems continue to operate as expected.

4. Scope of Hardening Measures

The hardening plan encompasses all VMs and network equipment in the Design world’s virtual infrastructure. Four Point Cyber Consultant will implement baseline security configurations on all VMs using STIG guidelines while focusing on the initially identified high-risk vulnerabilities.

		Security Hardening Plan and Project Change Request (PCR)	Client	Design World
			Doc #	DW0006
Effective Date	06/08/26		Rev. #	Rev 1

5. Hardening Measures

5.1 Configuration Changes

a. Domain Controller (DW-DC-OL-1)

- **Authentication Policy Enforcements:** Disable legacy LM and NTLMv1 network protocols and enforce NTLMv2 and Kerberos exclusively. (STIG: WN22-SO-000320)
- **Cryptographic Integrity:** Activate strict WinVerifyTrust signature verification to block spoofing attacks. (STIG: WN22-GE-000020)
- **Access Control Lists (ACLs):** Audit and correct insecure service permissions (DACLS) to eliminate local privilege escalation paths. (STIG: WN22-DC-000100)
- **Patch Management:** Apply missing security updates to remediate structural vulnerabilities. (STIG: WN22-PK-000010)

b. File Server (DW-FS-OL-1)

- **Protocol Transport Security:** Enforce SMB Signing to prevent Man-in-the-Middle (MitM) SMB relay attacks. (STIG: WN22-SO-000190)
- **Network File System (NFS) Restrictions:** Restrict file share visibility to specific authorized individuals to prevent NFS Shares from being world-readable. (STIG: WN22-00-000230)
- **Patch Management:** Apply missing security updates to remediate structural vulnerabilities. (STIG: WN22-PK-000010)
- **Authentication Policy Enforcements:** Disable legacy LM and NTLMv1 network protocols and enforce NTLMv2 and Kerberos exclusively. (STIG: WN22-SO-000320).

c. Ubuntu Workstation (DW-U22-OL-1)

- **Dependency and System Patching:** Update and upgrade the system to patch critical vulnerabilities discovered within the OpenSSL library binaries and other libraries. (STIG: UBTU-22-040200)
- **Secure Remote Administration:** Enforce cryptographically secure SSH communication. (STIG: UBTU-22-255050)

d. CentOS Web Server (DW-CS9W-OL-1)

- **Dependency and System Patching:** Update and upgrade the system to patch critical vulnerabilities. (STIG: RHEL-09-211015)

 FOUR POINT — CYBER CONSULTING —		Security Hardening Plan and Project Change Request (PCR)	Client	Design World
			Doc #	DW0006
Effective Date	06/08/26		Rev. #	Rev 1

- **Secure Remote Administration:** Enforce cryptographically secure SSH communication. (STIG: RHEL-09-255065).

e. Transit VLAN (DW-OpenVPN-Server-OL-1)

- **Management Protocol Decommissioning:** Disable unencrypted Telnet server daemons across all routers, switches, and edge hosts. (STIG: *NET-RTR-000120*)

5.2 Policy Changes

a. Authentication Hardening Policies

- **Disable Legacy Protocol:** LAN management authentication level must be set to NTLMv2 only

b. Session Integrity Policies

- **Enforce Domain SMB Signing:** Enable Microsoft network server: Digitally sign communications (always) and Microsoft network client: Digitally sign communications (always).

5.3 Security Control Updates

a. Automated Vulnerability Lifecycle Control

- **Baseline Compliance Auditing:** Deploy **DISA STIG Viewer** or automated SCC (Security Compliance Checker) scripts across Windows and Linux systems to establish an automated technical baseline mechanism, and alert teams if configurations drift back to unsafe legacy settings.
- **Continuous Update and Patch:** Establish and enforce a system update policy using a patch management system

b. Logging & Session Border Protections

- **Encrypted Management Communication:** Update the firewall rules to block port 23 (Telnet). Restrict port 22 (SSH) to traffic sourced from the OpenVPN client network (10.0.1.0/24).
- **Authentication Logging and Auditing:** Log all authentication and connection attempts and flag any unusual activity.

 FOUR POINT — CYBER CONSULTING —	Security Hardening Plan and Project Change Request (PCR)		Client	Design World
			Doc #	DW0006
			Rev. #	Rev 1
Effective Date	06/08/26			

6. Project Change Request Overview

The following Project Change Requests support the security hardening activities identified from the Vulnerability Assessment and Penetration Test. Each PCR addresses a specific system or security control area and requires approval from the Configuration Control Board before implementation.

- 1. PCR-001: Windows Server 2022 Domain Controller Hardening**
Apply missing security updates, disable legacy authentication, enable WinVerifyTrust mitigation, and correct insecure service permissions.
- 2. PCR-002: Windows Server 2022 File Server Hardening**
Apply missing security updates, enforce SMB signing, disable legacy authentication, and restrict insecure file sharing.
- 3. PCR-003: Ubuntu 22.04 Workstation Hardening**
Update vulnerable OpenSSL packages, remove package hold settings, disable Telnet, and strengthen SSH administration.
- 4. PCR-004: CentOS Stream 9 Web Server Hardening**
Apply system updates, harden web server configuration, and enforce secure remote administration.
- 5. PCR-005: OpenVPN and Transit VLAN Hardening**
Disable unencrypted management access, restrict SSH access, improve firewall rules, and strengthen logging of authentication activity.

7. Implementation Plan

7.1 Timeline

The security hardening activities will be completed within the approved implementation window after Design World and the Configuration Control Board approve the related Project Change Requests. The work will be scheduled during low-usage periods to reduce disruption to normal business operations and to limit the risk of service interruption.

Hardening will begin with the highest-risk systems, including the Windows Server 2022 Domain Controller and File Server. The team will then complete service hardening on the Ubuntu Workstation, CentOS Web Server, OpenVPN Server, and Transit Services VLAN. After the configuration changes are completed, Four Point Cyber Consulting will

 FOUR POINT — CYBER CONSULTING —		Security Hardening Plan and Project Change Request (PCR)	Client	Design World
			Doc #	DW0006
Effective Date	06/08/26		Rev. #	Rev 1

perform post-hardening validation to confirm that the approved changes were applied successfully and that system functionality remains available.

7.2 Resources

Four Point Cyber Consulting will assign the project lead, security engineer, security analyst, network engineer, and systems administrator to support the hardening effort. These team members will be responsible for planning the change window, applying approved configuration updates, validating system functionality, and documenting the results for the Security Hardening Report.

The team will use approved administrative access through the Design World sandbox environment, along with security tools needed for patch verification, configuration review, vulnerability scanning, and post-change testing. Design World will provide stakeholder support for approvals, coordination, and any required access confirmation during the implementation period.

7.3 Training

After implementation, Design World administrators will receive a short briefing on the security changes applied to the environment. The briefing will cover the updated patching process, approved remote access methods, disabled legacy protocols, SMB signing requirements, restricted NFS access, and expectations for secure system administration.

The training will also explain how administrators should monitor for configuration drift, review authentication logs, and follow the approved change process before making future security-related changes. This will help Design World maintain the hardening improvements and reduce the likelihood that insecure settings are reintroduced after the project is completed. After implementation, Design World administrators will receive a short briefing on the security changes applied to the environment. The briefing will cover the updated patching process, approved remote access methods, disabled legacy protocols, SMB signing requirements, restricted NFS access, and expectations for secure system administration.

The training will also explain how administrators should monitor for configuration drift, review authentication logs, and follow the approved change process before making future security-related changes. This will help Design World maintain the hardening

		Security Hardening Plan and Project Change Request (PCR)	Client	Design World
			Doc #	DW0006
Effective Date	06/08/26		Rev. #	Rev 1

improvements and reduce the likelihood that insecure settings are reintroduced after the project is completed.

8. Conclusion and Next Steps

The Security Hardening Plan and Project Change Requests provide Design World with a path for addressing the vulnerabilities confirmed during the Vulnerability Assessment and Penetration Test. The proposed hardening methods focus on reducing the most significant risks to the environment.

Approval from the Configuration Control Board is required before any hardening changes are implemented. Once approved, the Four Point Cyber Consulting team will complete the changes within the approved implementation window and in accordance with the documented Project Change Requests. The highest-risk systems, including the Windows Server 2022 Domain Controller and File Server, will be prioritized first, followed by the Ubuntu Workstation, CentOS Web Server, OpenVPN Server, and Transit Services VLAN.

After implementation, the Four Point Cyber Consulting team will validate that the approved changes were applied successfully and that system functionality remains available. This validation will include configuration review, patch verification, service testing, and follow-up vulnerability scanning as needed. Any issues identified during validation will be documented and addressed before the hardening effort is considered complete. This next phase will confirm whether the approved hardening measures improved the overall security posture of the sandbox environment and reduced the likelihood that the previously confirmed vulnerabilities can be exploited.

9. Attachments

1. PCR-001: Windows Server 2022 Domain Controller Hardening
2. PCR-002: Windows Server 2022 File Server Hardening
3. PCR-003: Ubuntu 22.04 Workstation Hardening
4. PCR-004: CentOS Stream 9 Web Server Hardening
5. PCR-005: OpenVPN and Transit VLAN Hardening

		Security Hardening Plan and Project Change Request (PCR)	Client	Design World
			Doc #	DW0006
			Rev. #	Rev 1
Effective Date	06/08/26			

10. Approvals

Role	Printed Name	Signature	Date
Project Lead	Christian Calipusan	<i>Christian Calipusan</i>	06/08/26
Security Analyst	Shivam Patel	<i>Shivam Patel</i>	06/08/26
Security Engineer	Joshua Remington	<i>Joshua Remington</i>	06/08/26
Network Engineer	Mikailou Nikiema	<i>Mikailou Nikiema</i>	06/08/26
DW CEO			